

הדרכת מודעות לאיומי סייבר 🎓

גירון – אבטחת מידע בסביבת העבודה

שקופית 1 – מבוא: מדוע אבטחת סייבר חשובה בגירון

גירון מנהלת נכסי נדל"ן להשכרה ומטפלת מדי יום במידע רגיש, לרבות חוזי שכירות, מסמכי זיהוי, רישומי תשלומים ונתונים פיננסיים. מידע זה בעל ערך רב לא רק לחברה אלא גם לפושעי סייבר המחפשים רווח כלכלי או ניצול נתונים. מתקפת סייבר מוצלחת עלולה לשבש את גביית שכר הדירה, לחשוף פרטים סודיים של דיירים ולפגוע במוניטין החברה. אפילו אירוע אבטחה קטן עלול להוביל לתוצאות משפטיות ולקנסות כספיים.

אבטחת סייבר אינה רק עניין טכני המטופל על ידי ה-IT – היא אחריות משותפת של כל העובדים. כל פעולה המבוצעת בתחנת העבודה של החברה יכולה להקטין או להגדיל את הסיכון הארגוני. הדרכה זו תסייע לכם להבין את האיומים העומדים בפנינו וכיצד להתמודד איתם באחריות.



שקופית 2 – מידע כנכס עסקי (יסודות ISO 27001)

תקן ISO/IEC 27001 מגדיר מידע כנכס עסקי קריטי הדורש הגנה שיטתית. בגירון, המידע כולל הסכמי שכירות, תיעוד ניהול נכסים, חוזי ספקים, תקשורת פנימית והנחיות תשלום. הגנה על מידע זה מחייבת שמירה על שלושה עקרונות יסוד: סודיות, שלמות וזמינות.

סודיות (Confidentiality) מבטיחה שרק אנשים מורשים יכולים לגשת לנתונים רגישים. שלמות (Integrity) מבטיחה שהמידע נשאר מדויק ולא שונה. זמינות (Availability) מבטיחה שהמערכות והרשומות נגישות בעת הצורך לצורכי תפעול. כל עובד תורם להגנה על שלושת העקרונות הללו באמצעות התנהגותו היומיומית וקבלת ההחלטות שלו.



שקופית 3 – הבנת הסביבה הטכנולוגית שלנו

עובדי גירון משתמשים בתחנות עבודה מבוססות Windows לביצוע תפקידיהם. כל המערכות התפעוליות, הדואר האלקטרוני ויישומי Office נגישים דרך סביבת Terminal Server מרכזית. הגדרה זו מספקת שליטה מרכזית ומשפרת את האבטחה הבסיסית של המערכות. עם זאת, Microsoft Teams פועל באופן מקומי בכל תחנת עבודה, מה שיוצר משטח חשיפה נפרד.

בנוסף, נקודות הקצה המקומיות (Endpoints) מוגנות בעיקר על ידי תוכנת אנטי-וירוס ולא על ידי מערכות הגנה מתקדמות (Advanced Endpoint Protection). חלק מהעובדים משתמשים במחשבים ניידים של החברה ומתחברים מרחוק דרך VPN, המרחיב את היקף הרשת מעבר לגבולות המשרד. הבנת הסביבה המעורבת הזו חיונית לזיהוי מקורות סיכונים הסייבר.



שקופית 4 – פגיעויות ב-Endpoint וסיכונים מקומיים

אף שמערכות הליבה מרוכזות, תחנת העבודה המקומית נותרת נקודת פגיעות קריטית. תוכנות זדוניות (Malware) המותקנות במחשב מקומי יכולות ללכוד פרטי כניסה, לתעד הקשות מקלדת (Keylogging) או לירות מפגשי תקשורת. תוכנת האנטי-וירוס מספקת הגנה בסיסית אך אינה חוסמת את כל האיומים המתקדמים.

תוקפי סייבר נוטים לנצל התנהגות משתמשים יותר מאשר חולשות טכניות. הורדת קבצים, גלישה באתרים לא בטוחים או התקנת אפליקציות לא מאושרות מגדילים את החשיפה. מחשב מקומי שנפגע יכול גם להשפיע על חיבורי VPN ומשאבים פנימיים. לכן על העובדים להתייחס לתחנת העבודה המקומית שלהם כ-Gateway רגיש אל תוך מערכות החברה.



שקופית 5 – איומי Phishing בענף הנדל"ן

מתקפות Phishing הן מהאימים הנפוצים ביותר בסביבות עבודה. תוקפים מתחזים לעיתים קרובות לדיירים, ספקים, בנקים ואף מנהלים פנימיים. בחברת נדל"ן כמו גירון, הודעות Phishing מתמקדות לעיתים קרובות בבקשות שינוי תשלום מזויפות או עדכוני חוזים דחופים. הודעות אלו מתוכננות ליצור דחיפות ולחץ רגשי.

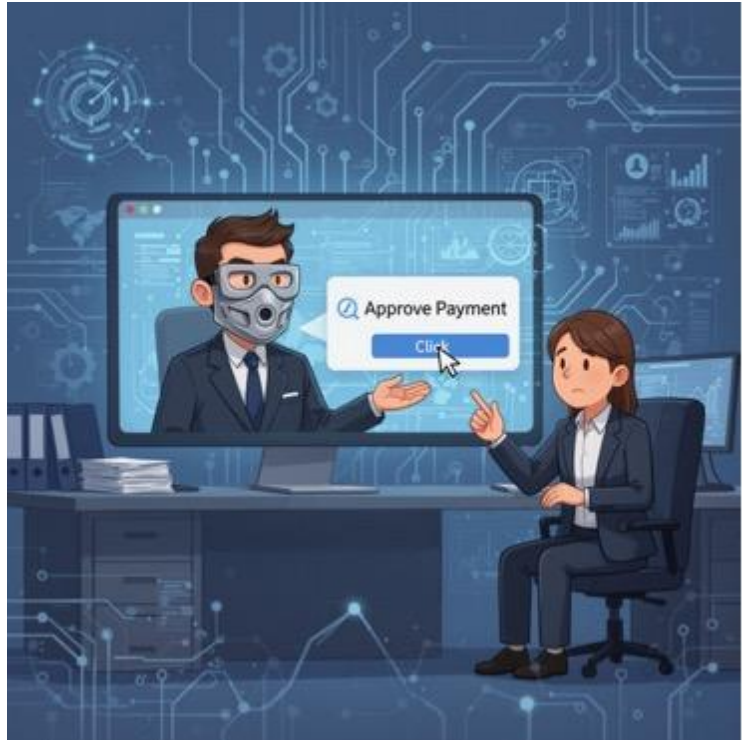
לחיצה על קישורים זדוניים עלולה להוביל לגניבת פרטי כניסה (Credential Theft) או להדבקה בתוכנות זדוניות. על העובדים לבחון בקפידה כתובות שולחים, קבצים מצורפים בלתי צפויים ובקשות חריגות. מומלץ תמיד לאמת באמצעות ערוצי תקשורת עצמאיים.



שקופית 6 – Spear Phishing והתחזות להנהלה

Spear Phishing היא גרסה מתוחכמת יותר של Phishing המכוונת לאנשים ספציפיים. התוקפים עשויים לחקור את מבנה החברה, פרופילי LinkedIn או מידע באתר לפני ניסוח הודעתם. לדוגמה, תוקף עשוי להתחזות למנמ"ר (CIO) או למנהל בכיר המבקש אישור פיננסי דחוף.

מתקפות אלו נראות לעיתים קרובות לגיטימיות ומקצועיות ביותר. תקן ISO 27001 מדגיש מודעות ותהליכי אימות פורמליים לצמצום סיכונים אלו. על העובדים לעולם לא לפעול על פי בקשות כספיות או גישה חריגות ללא אישור מפורש. ההיררכיה הארגונית אינה גוברת על נהלי האבטחה.



שקופית 7 – Ransomware ושיבוש תפעולי

Ransomware היא תוכנה זדונית המצפינה קבצים ודורשת תשלום עבור פענוחם. גם אם מערכות הליבה מתארחות ב-Ransomware Terminal Server, במקשיר מקומי יכול להתפשט או לסכן פרטי כניסה. אם מחשב נייד נגוע מתחבר דרך VPN, הוא עלול להכניס איומים לרשת הפנימית.

אירועי Ransomware יכולים לעצור את הפעילות, לחסום גישה לחוזים ולעכב עסקאות פיננסיות. תהליך ההתאוששות עשוי לארוך ימים או שבועות ולגרום נזק תדמיתי. הימנעות מהורדות חשודות ודיווח מהיר על חריגות הם אמצעי מניעה מרכזיים. גילוי מוקדם מצמצם משמעותית את הנזק.



שקופית 8 – VPN וסיכוני עבודה מרחוק

עבודה מרחוק מרחיבה את היקף האבטחה של החברה. כאשר עובדים מתחברים דרך VPN מהבית, סביבת הרשת הביתית שלהם הופכת לחלק ממשוואת האבטחה. סיסמאות Wi-Fi ביתיות חלשות או ראוטרים מיושנים מגדילים את הסיכון. רשתות Wi-Fi ציבוריות בבתי קפה או מלונות מסוכנות במיוחד.

גם עם הצפנת VPN, תוקפים עשויים לנסות מתקפות ברמת המכשיר. מחשבי חברה אסור לשתף עם בני משפחה או להשתמש בהם לפעילויות לא עסקיות. התנהגות מאובטחת מרחוק מגינה הן על העובד והן על הארגון.



שקופית 9 – Microsoft Teams כ-Attack Vector

Microsoft Teams פועל באופן מקומי בתחנות העבודה והמחשבים הניידים של גירון. תוקפים משתמשים יותר ויותר בכלי שיתוף פעולה להפצת קישורים זדוניים או מסמכים נגועים. חשבון עמית שנפרץ יכול להפיץ קבצים מזיקים פנימית. מכיוון ש-Teams מרגיש כפלטפורמה פנימית מהימנה, עובדים עשויים להוריד את רמת הערנות שלהם.

עם זאת, האימות נשאר חיוני, אפילו בתוך ערוצי תקשורת פנימיים. שיתוף קבצים בלתי צפוי צריך להיות מאושר בעל פה או דרך הודעה נפרדת. מודעות לאבטחת סייבר חלה על כל פלטפורמות התקשורת.



שקופית 10 – סיכויי מדיה נשלפת (התקני USB)

כוננוני USB קטנים אך נושאים איומים חזקים. תוכנות זדוניות יכולות להתבצע אוטומטית עם החדרה. בסביבות משרד משותפות, מכשירים לא מוכרים עלולים להיות מונחים בכוונה. תקן ISO 27001 דורש שליטה מחמירה בשימוש במדיה נשלפת.

יש להשתמש רק במכשירים מאושרים ומורשים. החדרת כוננוני USB לא מוכרים עלולה לסכן את כל תחנת העבודה. אם נמצא מכשיר ללא השגחה, יש לדווח על כך ל-IT מיד.



שקופית 11 – התקנת תוכנות לא מורשית

התקנת תוכנות לא מאושרות מכניסה פגיעויות לא ידועות לסביבה. כלי עזר חינוכיים ותוספות דפדפן כוללים לעיתים קרובות רכיבי Malware מוסתרים. אפילו כלים נראים לא מזיקים עלולים לשדר נתונים כלפי חוץ. תוכנות לא מורשות עלולות גם לעקוף בקורות אבטחה.

לפי מדיניות החברה, התקנה מחייבת אישור מהמנמ"ר (CIO). ביצוע תהליך זה מבטיח ניהול סיכונים מבוקר. הנוחות אינה גוברת על האבטחה בשום מקרה.



שקופית 12 – גלישה לא מוגבלת באינטרנט

גלישה ללא סינון חושפת עובדים לאתרים זדוניים. אתרים מסוימים מפיצים Malware באופן שקט ללא הורדות גלויות. הודעות עדכון מזויפות הן שיטות הדבקה נפוצות. על העובדים להיות זהירים בגלישה באתרים לא מוכרים. גלישה עסקית צריכה להישאר ממוקדת בעסק.

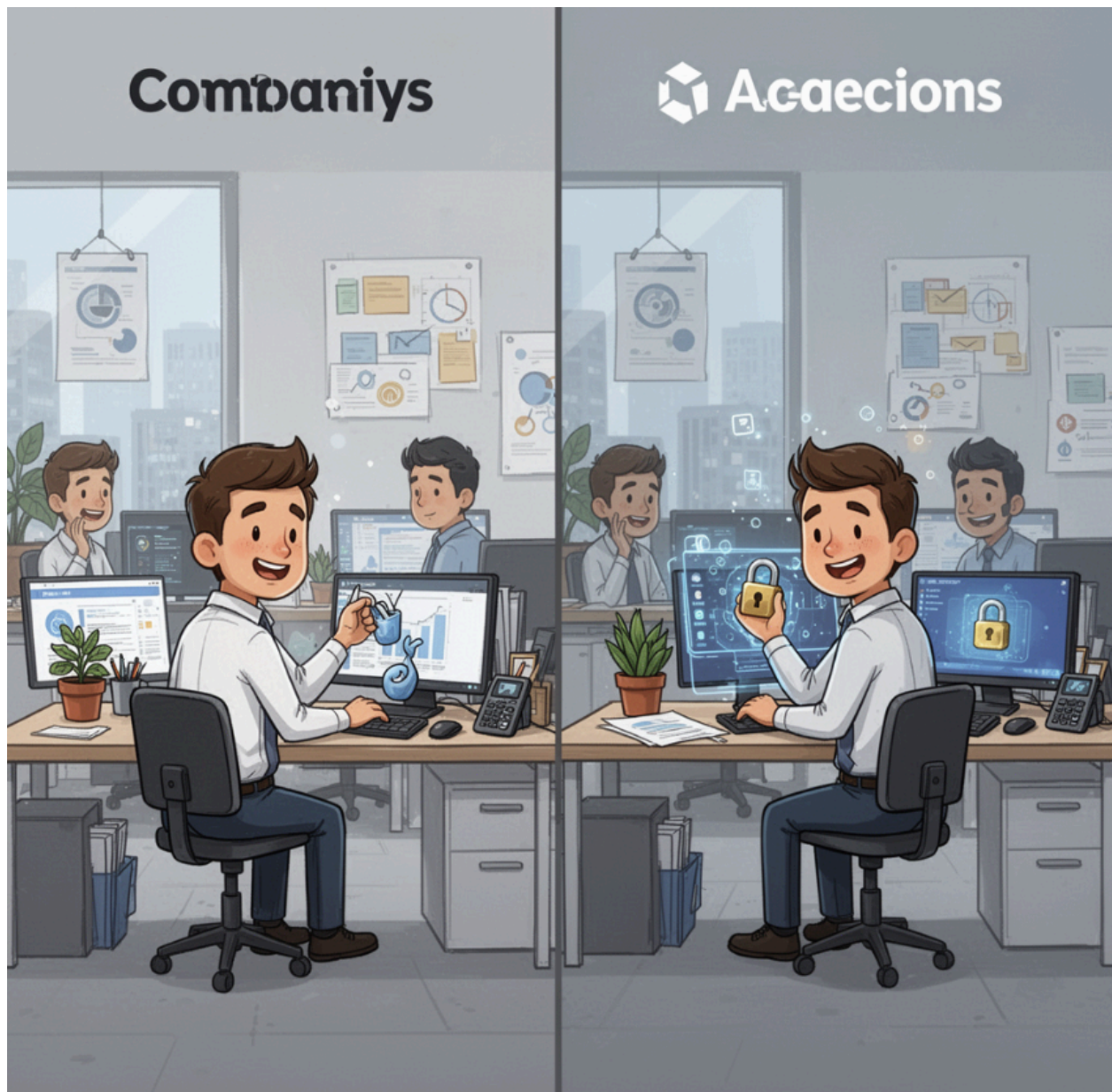
חלונות קופצים חשודים אין ללחוץ עליהם בשום מקרה. גלישה אחראית מצמצמת את הסיכון באופן משמעותי.



שקופית 13 – אבטחה פיזית במשרד משותף

מרחבי משרד משותפים מייצרים אתגרי אבטחה פיזיים. אנשים לא מורשים עשויים לצפות במסכים או לגשת למכשירים ללא השגחה. הצצה לכתף (Shoulder Surfing) היא טכניקה נפוצה לגניבת מידע. על תחנות עבודה להיות נעולות תמיד כשאין מלוות.

מסמכים רגישים אין להשאיר חשופים. האבטחה הפיזית משלימה את האבטחה הדיגיטלית. ערנות בסביבות משותפות היא חיונית.



שקופית 14 – מדיניות שולחן נקי ומסך נקי (Clean Desk & Clear Screen)

מדיניות שולחן נקי מצמצמת חשיפה מקרית של נתונים רגישים. מידע דיירים מודפס צריך להיות מאוחסן בצורה מאובטחת. על המסכים להיות נעולים בזמן היעדרויות קצרות. מסמכים סודיים אין להשאיר גלויים בן-לילה. מבקרים או עובדים חיצוניים עשויים לגשת למרחבים משותפים.

הרגלים פשוטים יוצרים שכבות הגנה חזקות. תרבות אבטחה מתחילה בדיסציפלינה יומיומית.



שקופית 15 – ניהול סיסמאות ואימות

סיסמאות חזקות הן בקורות אבטחה בסיסיות. סיסמאות חייבות להיות מורכבות וייחודיות לכל מערכת. שיתוף פרטי כניסה אסור בהחלט. Multi-Factor Authentication (אימות רב-שלבי) מוסיף שכבת הגנה נוספת. שימוש חוזר בסיסמאות מגדיל פגיעות בין פלטפורמות.

גניבת פרטי כניסה (Credential Theft) מתחילה לעיתים קרובות עם Phishing. התנהגות אימות מאובטחת מגינה על הארגון כולו.



שקופית 16 – מודעות להנדסה חברתית (Social Engineering)

תוקפי סייבר מנצלים אמון אנושי ודחיפות. הם עשויים להתקשר בטענה שהם תמיכת IT מ-Agas. הם עשויים לבקש איפוס סיסמאות או גישה מרחוק. הנדסה חברתית מסתמכת על לחץ רגשי. על העובדים לאמת זהות לפני שיתוף מידע.

אף ספק IT לגיטימי לא יבקש סיסמאות ישירות. מודעות מנטרלת ניסיונות מניפולציה.



שקופית 17 – סיווג מידע ובקרת גישה

לא לכל המידע יש אותה רגישות. רשומות פיננסיות של דיירים דורשות הגנה גבוהה יותר מרשימות נכסים ציבוריות. תקן ISO 27001 דורש בקרת גישה על בסיס צורך עסקי. עובדים לא צריכים לנסות לגשת לנתונים שאינם קשורים לתפקידם.

כיבוד גבולות הגישה מגן על הסודיות. שימוש לרעה בנתונים עשוי להוביל לפעולות משמעת. גישה מבוקרת מחזקת את החוסן הכולל.



שקופית 18 – תרבות דיווח על אירועים

דיווח מידי ממזער נזק מאירועי סייבר. חריגות קטנות עשויות לאותת על איומים גדולים יותר. דיווח מעודד ולא נענש. תגובה מוקדמת יכולה למנוע התפשטות IT Ransomware של Agas והמנמ"ר חייבים להיות מיידעים מיד.

שקיפות משפרת את ההגנה. מודעות קולקטיבית משפרת את בשלות האבטחה.



שקופית 19 – ממשל ורשות אישור

פעולות IT מנוהלות על ידי Agas, אך אחריות הממשל מוטלת על המנמ"ר (CIO). כל חריגה הכוללת שימוש ב-USB, התקנת תוכנה או אחסון נתונים מקומי מחייבת אישור מפורש. מדיניות מתוכננת להפחית חשיפה לסיכונים. עקיפת נהלים פוגעת בהגנה הארגונית.

החלטות אבטחה חייבות לעקוב אחר ערוצים פורמליים. אחריותות מבטיחה עקביות. הממשל תומך בעמידה בתקן ISO 27001.



שקופית 20 – בניית תרבות אבטחה בגירון

אבטחת סייבר היא תהליך מתמשך ולא יוזמה חד-פעמית. הטכנולוגיה לבדה אינה יכולה לבטל את הסיכון. מודעות עובדים היא מנגנון ההגנה החזק ביותר. התנהגות דיגיטלית אחראית מגינה על הדיירים ועל הפעילות העסקית.

דיווח על פעילות חשודה מחזק את החוסן. כל עובד ממלא תפקיד בשמירה על האבטחה. יחד, אנו יוצרים סביבה דיגיטלית בטוחה יותר.



שקופית 21 – תרחיש 1: דואר אלקטרוני חשוד לשינוי פרטי בנק

קיבלת דוא"ל שנראה כי הוא מדייר המבקש שינוי דחוף בפרטי העברת הבנק לתשלומי שכר דירה. הדוא"ל מסביר שחשבוננו "הוקפא" ומבקש לעדכן מיד את הוראות התשלום באמצעות קישור בהודעה. הטון דחוף ומדגיש הימנעות מאיחורים. שם השולח נראה נכון, אבל דומיין הדוא"ל נראה מעט חריג.

מה כדאי לעשות?

(א) לחץ על הקישור ועדכן את הפרטים מיד

(ב) הגב לדוא"ל ובקש אישור

(ג) דיווח על הדוא"ל ל-IT ואמת את הבקשה דרך מספר טלפון מוכר ☒ תשובה נכונה

הסבר:

תרחיש זה מייצג ניסיון Phishing קלאסי או Business Email Compromise, שכיח מאוד בחברות נדל"ן וניהול נכסים. תוקפים מתחזים לעיתים קרובות לדיירים או ספקים כדי להפנות תשלומים לחשבונות מזויפים. לחיצה על הקישור עלולה להוביל לגניבת פרטי כניסה או להתקנת תוכנה זדונית. מענה לאותה כתובת דוא"ל אינו מבטיח בטיחות, שכן התוקף שולט בתיבת הדואר הנכנס הזו. הגישה הבטוחה ביותר היא לאמת את הבקשה באמצעות מספר טלפון מהימן וידוע מראש – לא פרטי הקשר שסופקו בהודעה החשודה. דיווח על הדוא"ל ל-IT של Agas מאפשר חקירה טכנית ומגן על עובדים אחרים.



שקופית 22 – תרחיש 2: התקנת כלי PDF חינמי

אתה זקוק בדחיפות לאחד מספר חוזי PDF לפני שליחתם לדייר. חיפשת ברשת ומצאת כלי PDF חינמי המבטיח תוצאות מיידיות. האתר נראה מקצועי ומצהיר על שימוש נרחב. התקנתו תחסוך לך זמן ותסייע לך לעמוד בלוח הזמנים.

מה כדאי לעשות?

(א) התקן את הכלי מיד

(ב) בקש אישור מהמנמ"ר לפני ההתקנה ☒ תשובה נכונה

(ג) העלה את המסמכים לאתר ומזג אותם באינטרנט

הסבר:

התקנת תוכנות לא מורשות מכניסה סיכונים לא ידועים לתחנת העבודה. אפילו אתרים נראים מקצועיים עשויים להפיץ Malware המוסווה ככלים לגיטימיים. העלאת חוזים סודיים לאתרים חיצוניים עלולה לחשוף מידע רגיש של דיירים ולהפר מדיניות הגנת נתונים. אף שמערכות הליבה מתארחות ב-Terminal Server, Malware-VPN על המכשיר המקומי יכול ללכוד פרטי כניסה או להתפשט דרך VPN. תקן ISO 27001 מדגיש ניהול תוכנה מבוקר ותהליכי אישור פורמליים.



שקופית 23 – תרחיש 3: כונן USB שנמצא במשרד משותף

בזמן עבודה במרחב משרד משותף, מצאת כונן USB ליד המדפסת. הוא לא מסומן ונראה שנשאר שם. אתה מתעניין אם הוא שייך למישהו בגירון ושוקל לחבר אותו לתחנת העבודה שלך כדי לזהות את הבעלים.

מה כדאי לעשות?

(א) הכנס אותו למחשב שלך כדי לבדוק את תוכנו

(ב) מסור אותו ל-IT של Agas מבלי לחבר אותו ☒ תשובה נכונה

(ג) השאר אותו במקום שמצאת

הסבר:

מכשירי USB לא מוכרים הם שיטת מתקפת סייבר מתועדת היטב הידועה בשם "USB Drop Attack". תוקפים מניחים בכוונה מכשירים נגועים במקומות ציבוריים או משותפים, בתקווה שמישהו יחבר אותם. עם החדרה, Malware עלול להתבצע אוטומטית ללא אזהרה גלויה. מכיוון שמשרדי גירון לעיתים משותפים עם חברות אחרות, סיכוני מכשירים פיזיים מוגברים. אפילו תוכנת אנטי-וירוס עשויה לא לזהות אינדים מתקדמים מיד. מסירת המכשיר ישירות ל-IT מבטיחה ניתוח נאות בסביבה מבוקרת.



שקופית 24 – תרחיש 4: התחברות דרך VPN מבית קפה

אתה עובד מרחוק על המחשב הנייד שלך ומחליט להתחבר מרשת Wi-Fi ציבורית בבית קפה. אתה מפעיל את ה-VPN ומתחבר למערכות החברה דרך Terminal Server. אתה מניח שמכיוון שהצפנת VPN פעילה, החיבור מאובטח לחלוטין.

מה כדאי לעשות?

(א) המשך לעבוד כרגיל כי VPN מבטיח בטיחות

(ב) הימנע מ-Wi-Fi ציבורי או השתמש ב-Hotspot אישי מאובטח ☒ תשובה נכונה

(ג) השבת אנטי-וירוס כי VPN פעיל

הסבר:

בעוד ש-VPN מצפין תעבורה בין המכשיר לרשת החברה, הוא אינו מבטל את כל הסיכונים הקשורים ל-Wi-Fi ציבורי. תוקפים באותה רשת עשויים לנסות מתקפות ברמת המכשיר או לנצל פגיעויות שלא תוקנו. רשתות ציבוריות ממוקדות לעיתים קרובות על ידי פושעי סייבר. שימוש ב-Hotspot אישי מאובטח או ברשת פרטית מהימנה מצמצם משמעותית את החשיפה. מחשבי חברה מרחיבים את היקף האבטחה הארגוני לכל מקום בו הם נמצאים. תקן ISO 27001 דורש ניהול סיכונים לסביבות עבודה מרחוק.



שקופית 25 – תרחיש 5: קובץ בלתי צפוי ב-Microsoft Teams

עמית שולח לך קובץ דרך Microsoft Teams עם הכותרת "תבנית חוזה מעודכנת". לא ציפית לקובץ זה ולא ביקשת עדכונים. ההודעה מכילה רק את הקובץ ללא הסבר נוסף.

מה כדאי לעשות?

(א) פתח את הקובץ מיד מכיוון שהגיע מעמית

(ב) **אמת עם העמית לפני פתיחה** ✓ **תשובה נכונה**

(ג) העבר את הקובץ לאחרים לעיון

הסבר:

פושעי סייבר פורצים לחשבונות לגיטימיים יותר ויותר כדי להפיץ Malware פנימית. אפילו פלטפורמות מהימנות כמו Microsoft Teams יכולות להפוך לערוצי מתקפה. אם חשבון עמית נפרץ, קבצים זדוניים עשויים להישלח אוטומטית. פתיחת הקובץ ללא אימות עלולה להפעיל Malware על תחנת העבודה המקומית. מכיוון ש-Teams פועל באופן מקומי בגירון, הסיכון קשור ישירות למכשיר הקצה. אישור דרך הודעה מהירה או שיחת טלפון מבטיח אמיתות. האמון חייב תמיד להיות מאומת בתקשורת דיגיטלית.



שקופית 26 – תרחיש 6: עזיבת השולחן לזמן קצר

אתה עוזב את תחנת העבודה שלך לחמש דקות כדי להשתתף בדיון קצר. אתה עובד במשרד משותף שבו גם עובדים מחברות אחרות. מסכך מציג כרגע מידע פיננסי של דיירים.

מה כדאי לעשות?

(א) השאר את המסך פתוח כי תחזור בקרוב

(ב) **נעל את תחנת העבודה לפני העזיבה** ✓ **תשובה נכונה**

(ג) סגור את האפליקציה אך השאר Windows ללא נעילה

הסבר:

אפילו היעדרויות קצרות יוצרות הזדמנויות לצפייה לא מורשית או חשיפת נתונים. במשרדים משותפים, אנשים שאינם עובדי גירון עשויים להימצא בסביבה. הצצה לכתף (Shoulder Surfing) וצפייה מקרית עלולים להוביל להפרות סודיות. נעילת תחנת העבודה אורכת רק שניות ומצמצמת את הסיכון באופן משמעותי. תקן ISO 27001 מדגיש אבטחה פיזית ומדיניות מסך נקי כחלק מהגנת המידע. נתוני דיירים ומידע פיננסי אסור שיישארו גלויים. הרגלים קטנים יוצרים תרבות אבטחה חזקה ומדגימים אחריות מקצועית.

